

Security+ 5.3 · Third-party Risk Assessment

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.3 — Third-party Risk Assessment (11:36)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: TPRM: right-to-audit clause (contract ALLOWS you to audit); supply chain analysis (who supplies the supplier); vendor monitoring (continuous security posture).

High-Yield Core Concepts Tested on Exam

- TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor
- Right-to-audit: contract clause allowing you to audit the vendor
- Supply chain analysis: assess vendors of your vendors (nth-party risk)
- Vendor monitoring: ongoing assessment of vendor security posture, not just at onboarding
- TPRM includes due diligence, contractual controls, and periodic reassessment

Exam Tips & Classic Scenarios

- 'contract clause allowing security audits of vendor' = right-to-audit
- 'assessing the security of a vendor's suppliers' = supply chain analysis
- 'continuous monitoring of vendor security' = vendor monitoring

Typical Exam Scenario: 'Contract allows auditing the vendor' = right-to-audit clause.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.3 — Third-party Risk Assessment)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor...

2. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'Right-to-audit: clause that lets you audit the vendor.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Right-to-audit: clause that lets you audit the vendor...
- D)** Allow shared access among administrators using generic credentials

3. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'contract clause allowing security audits of vendor' = right-to-audit. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'contract clause allowing security audits of vendor' = right-to-audit...
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'contract allows auditing the supplier'=right-to-audit clause.'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'contract allows auditing the supplier'=right-to-audit clause...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor.

6. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'Right-to-audit: clause that lets you audit the vendor'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Right-to-audit: clause that lets you audit the vendor...
- B)** Temporarily disable audit logs to speed up system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'contract clause allowing security audits of vendor'=right-to-audit'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'contract clause allowing security audits of vendor'=right-to-audit...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'contract allows auditing the vendor' = right-to-audit clause.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'contract allows auditing the vendor' = right-to-audit clause...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'TPRM: assess, contract, MONITOR the vendor continuously'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: TPRM: assess, contract, MONITOR the vendor continuously...
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Third-party Risk Assessment): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.3), an analyst evaluates the following technical requirement: 'Right-to-audit: clause that allows you to audit the vendor.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Right-to-audit: clause that allows you to audit the vendor...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) D — Implement the corresponding solution: TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor. Third-Party Risk Management (TPRM) is a continuous lifecycle process that includes due diligence before engagement, contractual security requirements, and ongoing monitoring of the vendor's security posture to detect changes in risk.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

2) C — Implement the corresponding solution: Right-to-audit: clause that lets you audit the vendor....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): Right-to-audit: clause that lets you audit the vendor. A right-to-audit clause in a contract grants the organization the right to audit the vendor's security controls and practices. The correct action is to implement the corresponding contractual clause.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) C — Implement the corresponding solution: 'contract clause allowing security audits of vendor' = right-to-audit....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): 'contract clause allowing security audits of vendor' = right-to-audit.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: 'contract allows auditing the supplier'=right-to-audit clause....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): 'contract allows auditing the supplier'=right-to-audit clause.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): TPRM: assess, contract, and CONTINUOUSLY MONITOR the vendor. Third-party risk management (TPRM) involves ongoing evaluation of vendors' security posture, contractual security requirements, and continuous monitoring to detect changes in risk.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Right-to-audit: clause that lets you audit the vendor....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): Right-to-audit: clause that lets you audit the vendor.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'contract clause allowing security audits of vendor'=right-to-audit....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): 'contract clause allowing security audits of vendor'=right-to-audit.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) A — Implement the corresponding solution: 'contract allows auditing the vendor' = right-to-audit clause....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): 'contract allows auditing the vendor' = right-to-audit clause. A right-to-audit clause in a contract grants the organization the ability to audit the vendor's security controls and practices, ensuring compliance and mitigating third-party risks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: TPRM: assess, contract, MONITOR the vendor continuously....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): TPRM: assess, contract, MONITOR the vendor continuously.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) A — Implement the corresponding solution: Right-to-audit: clause that allows you to audit the vendor....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.3 (Third-party Risk Assessment): Right-to-audit: clause that allows you to audit the vendor.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.